Ciberdelitos y Regulación de la Ciberseguridad

Tema 3. Normativa en materia de ciberseguridad

Índice

Esquema

Ideas clave

3.1. Introducción y objetivos

3.2. Directiva 2016/1148 NIS o de ciberseguridad

3.3. Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información

3.4. Real Decreto 43/2021, de 26 de enero, por el que se desarrolla el Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información

3.5. Nuevo paquete de ciberseguridad de la Unión Europea

3.6. Directiva (UE) 2022/2555 relativa a las medidas destinadas a garantizar un elevado nivel común de ciberseguridad en toda la Unión (Directiva NIS 2)

3.7. Directiva (UE) 2022/2557 del Parlamento Europeo y del Consejo de 14 de diciembre de 2022 relativa a la resiliencia de las entidades críticas

3.8. Reglamento de Ciberseguridad de la UE

3.9. Reglamento sobre Ciberseguridad de la UE (CRA)

3.10. Otras normas

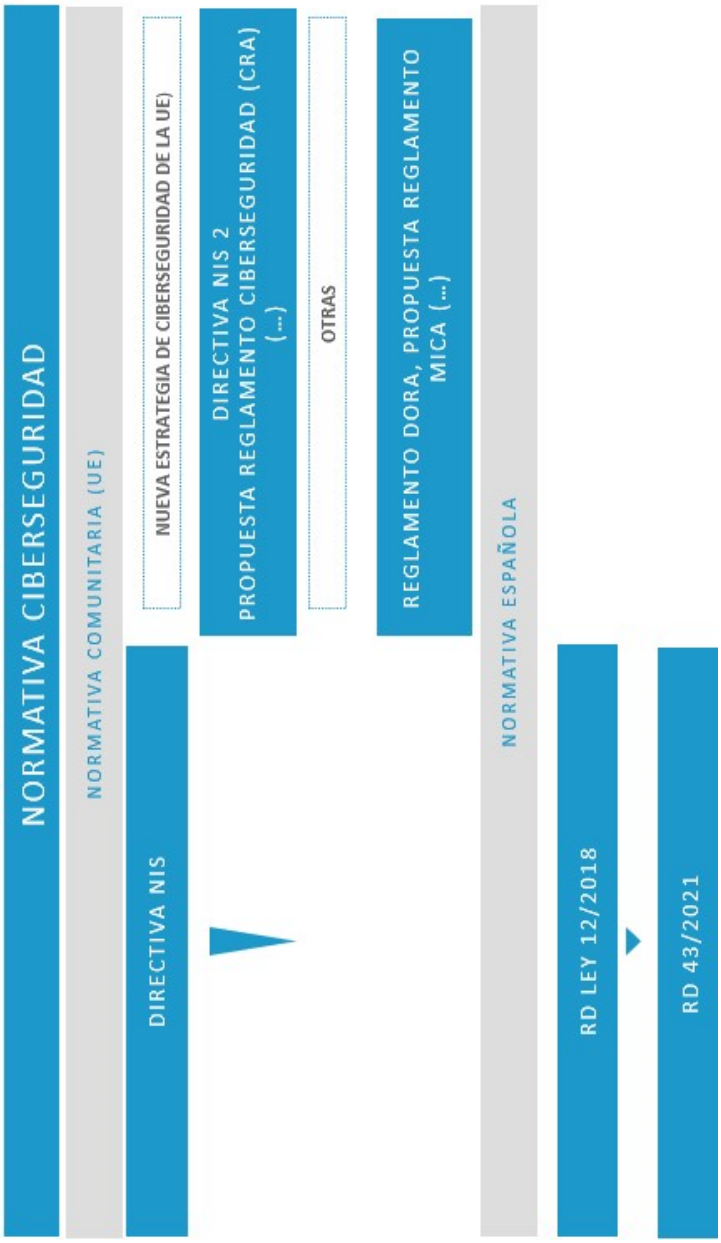
3.11. Referencias bibliográficas

A fondo

Guía nacional de notificación y gestión de ciberincidentes

Test

Esquema



© Universidad Internacional de La Rioja (UNIR)

3.1. Introducción y objetivos

Los objetivos que se pretenden conseguir en el presente tema son:

- Conocer la principal normativa vigente en materia de ciberseguridad, tanto en el ámbito europeo como en el nacional.
- Conocer e interpretar la terminología legal.

© Universidad Internacional de La Rioja (UNIR)

3.2. Directiva 2016/1148 NIS o de ciberseguridad

La Directiva (UE) 2016/1148, de 6 de julio de 2016, relativa a las medidas destinadas a garantizar un elevado nivel común de seguridad de las redes y sistemas de información en la Unión (conocida como Directiva sobre ciberseguridad o Directiva NIS) tiene por objeto establecer medidas para «lograr un elevado nivel común de seguridad de las redes y sistemas de información dentro de la Unión a fin de mejorar el funcionamiento del mercado interior» (art. 1.1, Dir. NIS) dado que:

> «la magnitud, la frecuencia y los efectos de los incidentes de seguridad se están incrementando y representan una grave amenaza para el funcionamiento de las redes y sistemas de información. Esos sistemas pueden convertirse además en objetivo de acciones nocivas deliberadas destinadas a perjudicar o interrumpir su funcionamiento. Este tipo de incidentes puede interrumpir las actividades económicas, generar considerables pérdidas financieras, menoscabar la confianza del usuario y causar grandes daños a la economía de la Unión Europea» (cdo. 2, Dir. NIS).

La Directiva NIS entró en vigor el 19 de julio de 2016 y **su objetivo** es realizar «un planteamiento global en la Unión que integre requisitos mínimos comunes en materia de desarrollo de capacidades y planificación, intercambio de información, cooperación y requisitos comunes de seguridad para los operadores de servicios esenciales y los proveedores de servicios digitales» (cdo. 6, Dir. NIS).

Actualmente, ya se ha aprobado la Directiva NIS 2, que deroga la Directiva NIS a partir del 18 de octubre de 2024 (Art 44 de la Directiva NIS 2). No obstante, para poder apreciar los cambios entre ambas directivas, así como la normativa española que las transpone, dedicaremos el presente apartado a la Directiva NIS.

Por lo que respecta a los **destinatarios** de la Directiva NIS, esta «debe aplicarse tanto a los operadores de servicios esenciales como a los proveedores de servicios

© Universidad Internacional de La Rioja (UNIR)

digitales» (cdo. 7, Dir. NIS), pero no a las empresas que suministren redes públicas de comunicaciones o presten servicios de comunicaciones electrónicas disponibles para el público, ni a los prestadores de servicios de confianza definidos en el Reglamento (UE) n.o 910/2014 del Parlamento Europeo y del Consejo que están sujetos a los requisitos de seguridad establecidos en dicho reglamento (cdo. 7, Dir. NIS).

Respecto a los operadores de servicios esenciales, la Directiva NIS establece que «a más tardar el 9 de noviembre de 2018, los Estados miembros identificarán a los operadores de servicios esenciales establecidos en su territorio para cada sector y subsector mencionados en el anexo II» (art. 5).

Asimismo, esta directiva lo es «sin perjuicio de que los Estados miembros puedan adoptar las medidas necesarias para garantizar la protección de los intereses esenciales de su seguridad, preservar el orden público y la seguridad pública, y permitir la investigación, detección y enjuiciamiento de infracciones penales» (cdo. 8, Dir. NIS).

En cuanto al análisis de esta directiva, podemos distinguir entre sus principales aportaciones:

El **objeto,** que es el siguiente:

> «a) establece obligaciones para todos los Estados miembros de adoptar una estrategia nacional de seguridad de las redes y sistemas de información;
>
> »b) crea un Grupo de cooperación para apoyar y facilitar la cooperación estratégica y el intercambio de información entre los Estados miembros y desarrollar la confianza y seguridad entre ellos;
>
> »c) crea una red de equipos de respuesta a incidentes de seguridad informática (en lo sucesivo, «red de CSIRT», por sus siglas en inglés de «computer security incident response teams») con el fin de contribuir al desarrollo de la confianza y seguridad entre los Estados miembros y promover una cooperación operativa rápida y eficaz;
>
> »d) establece requisitos en materia de seguridad y notificación para los operadores de

© Universidad Internacional de La Rioja (UNIR)

servicios esenciales y para los proveedores de servicios digitales;

»e) establece obligaciones para que los Estados miembros designen autoridades nacionales competentes, puntos de contacto únicos y CSIRT con funciones relacionadas con la seguridad de las redes y sistemas de información» (art. 1.2, Dir. NIS).

Dentro del capítulo II de la Directiva NIS (denominado «Marcos nacionales de seguridad de las redes y sistemas de información»), el artículo 7 contempla la obligación de que «cada Estado miembro adoptará una estrategia nacional de seguridad de las redes y sistemas de información que establezca los objetivos estratégicos y las medidas políticas y normativas adecuadas con objeto de alcanzar y mantener un elevado nivel de seguridad de las redes y sistemas de información y que cubra al menos los sectores que figuran en el anexo II y los servicios que figuran en el anexo III» de la propia directiva. Asimismo, indica las cuestiones que deberá abordar como mínimo la estrategia nacional de seguridad de las redes y sistemas de información, que son las siguientes:

«a) los objetivos y prioridades de la estrategia nacional de seguridad de las redes y sistemas de información;

»b) un marco de gobernanza para lograr los objetivos y las prioridades de la estrategia nacional de seguridad de las redes y sistemas de información, incluidas las funciones y responsabilidades de las instituciones públicas y de los demás agentes pertinentes;

»c) la identificación de medidas sobre preparación, respuesta y recuperación, incluida la cooperación entre los sectores público y privado;

»d) una indicación de los programas de educación, concienciación y formación relacionados con la estrategia nacional de seguridad de las redes y sistemas de información;

»e) una indicación de los programas de investigación y desarrollo relacionados con la estrategia nacional de seguridad de las redes y sistemas de información;

»f) un plan de evaluación de riesgos para identificar riesgos;

»g) una lista de los diversos agentes que participan en la ejecución de la estrategia de seguridad de las redes y sistemas de información» (art. 7.1, Dir. NIS).

© Universidad Internacional de La Rioja (UNIR)

Asimismo, se indica que:

> «1. Cada Estado miembro designará una o más autoridades nacionales competentes en materia de seguridad de las redes y sistemas de información (en lo sucesivo, «autoridad competente») que cubra al menos los sectores que figuran en el anexo II y los servicios que figuran en el anexo III. Los Estados miembros podrán asignar esta función a una autoridad o autoridades existentes.
>
> »2. Las autoridades competentes supervisarán la aplicación de la presente Directiva a escala nacional» (art. 8, Dir. NIS).

También se hace referencia a los **equipos de respuesta a incidentes de seguridad informática (CSIRT)** indicando que: «cada Estado miembro designará uno o varios CSIRT que cumplan los requisitos establecidos en el anexo I, punto 1, que cubran al menos los sectores que figuran en el anexo II y los tipos de servicios digitales que figuran en el anexo III, responsables de la gestión de incidentes y riesgos de conformidad con un procedimiento claramente definido» (art. 9, Dir. NIS). Se aclara, no obstante, que «podrá crearse un CSIRT en el marco de una autoridad competente» (art. 9, Dir. NIS).

En el capítulo III, titulado «Cooperación», se regula el **grupo de cooperación,** la red de CSIRT y la cooperación internacional: «se establece un Grupo de cooperación a fin de apoyar y facilitar la cooperación estratégica y el intercambio de información entre los Estados miembros y desarrollar confianza y seguridad, y a fin de alcanzar un elevado nivel común de seguridad de las redes y sistemas de información en la Unión» (art. 11, Dir. NIS).

El capítulo IV se refiere a «Seguridad de las redes y sistemas de información de los operadores de servicios esenciales» y en él se regulan los requisitos en materia de **seguridad y notificación de incidentes** y la aplicación y observancia en los siguientes términos: «los Estados miembros velarán porque los operadores de servicios esenciales tomen las medidas técnicas y de organización adecuadas y proporcionadas para gestionar los riesgos que se planteen para la seguridad de las

© Universidad Internacional de La Rioja (UNIR)

redes y sistemas de información que utilizan en sus operaciones. Habida cuenta de la situación, dichas medidas garantizarán un nivel de seguridad de las redes y sistemas de información adecuado en relación con el riesgo planteado» (art. 14, Dir. NIS).

El capítulo V habla de «Seguridad de las redes y sistemas de información de los proveedores de servicios digitales». Regula los requisitos en materia de **seguridad y notificación de incidentes,** la aplicación y observancia y la jurisdicción y territorialidad:

> «Los Estados miembros velarán por que los proveedores de servicios digitales determinen y adopten medidas técnicas y organizativas adecuadas y proporcionadas para gestionar los riesgos existentes para la seguridad de las redes y sistemas de información que se utilizan en el marco de la oferta de servicios en la Unión a que se refiere el anexo III. Habida cuenta de los avances técnicos, dichas medidas garantizarán un nivel de seguridad de las redes y los sistemas de información adecuado en relación con el riesgo planteado» (art. 16, Dir. NIS).

Del capítulo VI, sobre la «Normalización y notificación voluntaria», destacamos que: «los Estados miembros fomentarán, sin imponer ni favorecer el uso de un tipo específico de tecnología, la utilización de normas y especificaciones aceptadas a nivel europeo o internacionalmente que sean pertinentes en materia de seguridad de las redes y sistemas de información» (art. 19, Dir. NIS).

El capítulo VII está reservado a «Disposiciones finales» y se refiere a sanciones, medidas transitorias, transposición, entrada en vigor, destinatarios de la norma, etc. Destacamos un par de aspectos: «los Estados miembros establecerán el régimen de sanciones aplicables en caso de incumplimiento de las disposiciones nacionales aprobadas al amparo de la presente directiva y adoptarán todas las medidas necesarias para garantizar su aplicación. Tales sanciones serán efectivas, proporcionadas y disuasorias» (art. 21, Dir. NIS).

En cuanto a la transposición, se prevé que «los Estados miembros adoptarán y

© Universidad Internacional de La Rioja (UNIR)

publicarán, a más tardar el 9 de mayo de 2018, las disposiciones legales, reglamentarias y administrativas necesarias para dar cumplimiento a lo establecido en la presente Directiva. Informarán de ello inmediatamente a la Comisión. Aplicarán esas medidas a partir del 10 de mayo de 2018» (art. 25, Dir. NIS).

Por último, se incluyen **tres anexos:**

- Requisitos y funciones de los equipos de respuesta a incidentes de seguridad informática (CSIRT).
- Tipos de entidades a efectos del artículo 4.4.
- Tipos de servicios digitales a efectos del artículo 4.5.

De lo anterior se deduce que:

- Por un lado, la Directiva NIS implicará la aprobación de disposiciones en nuestro ordenamiento para garantizar su correcta transposición.
- Por otro lado, habrá que adecuar la actual Estrategia Nacional de Ciberseguridad a lo que dispone la directiva, designándose las autoridades, puntos de contacto y centros de respuesta, etc. oportunos.
- Por último, habrá que adecuarse y coordinarse con lo establecido en el RGPD.

© Universidad Internacional de La Rioja (UNIR)

3.3. Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información

Mediante el Real Decreto-ley 12/2018 se transpone al derecho español la Directiva NIS.

Tiene por **objeto** «regular la seguridad de las redes y sistemas de información utilizados para la provisión de los servicios esenciales y de los servicios digitales, y establecer un sistema de notificación de incidentes» (art 1.1, RD-L 12/2018).

Servicios esenciales y servicios digitales

Este real decreto-ley se aplica a:

> «a) Los servicios esenciales dependientes de las redes y sistemas de información comprendidos en los sectores estratégicos definidos en el anexo de la Ley 8/2011, de 28 de abril, por la que se establecen medidas para la protección de las infraestructuras críticas.
>
> »b) Los servicios digitales [servicios de la sociedad de la información] que sean mercados en línea, motores de búsqueda en línea y servicios de computación en nube» (art. 2.1, RD-L 12/2018).

El artículo 6 establece que:

> «1. La identificación de los servicios esenciales y de los operadores que los presten se efectuará por los órganos y procedimientos previstos por la Ley 8/2011, de 28 de abril, y su normativa de desarrollo.
>
> »La relación de los servicios esenciales y de los operadores de dichos servicios se actualizará, para cada sector, con una frecuencia bienal, en conjunción con la revisión de los planes estratégicos sectoriales previstos en la Ley 8/2011, de 28 de abril.
>
> »Se identificará a un operador como operador de servicios esenciales si un incidente sufrido por el operador puede llegar a tener efectos perturbadores significativos en la prestación del servicio, para lo que se tendrán en cuenta, al menos, los siguientes

© Universidad Internacional de La Rioja (UNIR)

factores:

»a) En relación con la importancia del servicio prestado:

»1.o La disponibilidad de alternativas para mantener un nivel suficiente de prestación del servicio esencial;

»2.o La valoración del impacto de un incidente en la provisión del servicio, evaluando la extensión o zonas geográficas que podrían verse afectadas por el incidente; la dependencia de otros sectores estratégicos respecto del servicio esencial ofrecido por la entidad y la repercusión, en términos de grado y duración, del incidente en las actividades económicas y sociales o en la seguridad pública.

»b) En relación con los clientes de la entidad evaluada:

»1.o El número de usuarios que confían en los servicios prestados por ella;

»2.o Su cuota de mercado» (art. 6.1, RD-L 12/2018).

Autoridades competentes

Las autoridades competentes en materia de seguridad de las redes y sistemas de información son:

«a) Para los operadores de servicios esenciales:

»1.o En el caso de que éstos sean, además, designados como operadores críticos conforme a la Ley 8/2011, de 28 de abril, y su normativa de desarrollo, con independencia del sector estratégico en que se realice tal designación: la Secretaría de Estado de Seguridad, del Ministerio del Interior, a través del Centro Nacional de Protección de Infraestructuras y Ciberseguridad (CNPIC).

»2.o En el caso de que no sean operadores críticos: la autoridad sectorial correspondiente por razón de la materia, según se determine reglamentariamente.

»b) Para los proveedores de servicios digitales: la Secretaría de Estado para el Avance Digital, del Ministerio de Economía y Empresa.

»c) Para los operadores de servicios esenciales y proveedores de servicios digitales que no siendo operadores críticos se encuentren comprendidos en el ámbito de aplicación de la Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público: el Ministerio de Defensa, a través del Centro Criptológico Nacional» (art. 9.1, RD-L 12/2018).

Punto de contacto único

© Universidad Internacional de La Rioja (UNIR)

«El Consejo de Seguridad Nacional ejercerá, a través del Departamento de Seguridad Nacional, una función de enlace para garantizar la cooperación transfronteriza de» (art. 13, RD-L 12/2018):

- Las autoridades competentes (designadas de acuerdo con artículo 9).
- Las autoridades competentes de otros Estados miembros de la UE.
- El grupo de cooperación y la red de CSIRT.

Notificación de incidentes

«Los operadores de servicios esenciales notificarán a la autoridad competente, a través del CSIRT de referencia, los incidentes que puedan tener efectos perturbadores significativos en dichos servicios» (art. 19.1, RD-L 12/2018).

Por otro lado, «los proveedores de servicios digitales notificarán a la autoridad competente, a través del CSIRT de referencia, los incidentes que tengan efectos perturbadores significativos en dichos servicios. La obligación de la notificación del incidente únicamente se aplicará cuando el proveedor de servicios digitales tenga acceso a la información necesaria para valorar el impacto de un incidente» (art. 19.2, RD-L 12/2018).

El párrafo tercero establece que «las notificaciones tanto de operadores de servicios esenciales como de proveedores de servicios digitales se referirán a los incidentes que afecten a las redes y sistemas de información empleados en la prestación de los servicios indicados, tanto si se trata de redes y servicios propios como si lo son de proveedores externos, incluso si éstos son proveedores de servicios digitales sometidos a este real decreto-ley» (art. 19.3, RD-L 12/2018).

© Universidad Internacional de La Rioja (UNIR)

El párrafo cuarto concreta que «las autoridades competentes y los CSIRT de referencia utilizarán una plataforma común para facilitar y automatizar los procesos de notificación, comunicación e información sobre incidentes» (art. 19.4, RD-L 12/2018).

Obligaciones

Tal y como se establece en el preámbulo: «los operadores de servicios esenciales y los proveedores de servicios digitales deberán adoptar medidas adecuadas para gestionar los riesgos que se planteen para la seguridad de las redes y sistemas de información que utilicen, aunque su gestión esté externalizada. Las obligaciones de seguridad que asuman deberán ser proporcionadas al nivel de riesgo que afronten y estar basadas en una evaluación previa de los mismos» (RD-L 12/2018).

Se deja la puerta abierta a que la norma que desarrolle este real decreto-ley pueda concretar las obligaciones de seguridad exigibles a los operadores de servicios esenciales.

Por tanto, las obligaciones principales que establece el RD-L 12/2018 son:

- Realización de un análisis de riesgos.
- Implementación de medidas derivadas del análisis de riesgos.
- Notificación de incidentes de seguridad a través del CSIRT de referencia.

© Universidad Internacional de La Rioja (UNIR)

3.4. Real Decreto 43/2021, de 26 de enero, por el que se desarrolla el Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información

Este real decreto (RD 43/2021) desarrolla el Real Decreto-ley por el que se transpone la Directiva NIS.

En cuanto a su **ámbito de aplicación,** este RD aplica a los siguientes servicios:

> «a) Los servicios esenciales dependientes de las redes y sistemas de información comprendidos en los sectores estratégicos definidos en el anexo de la Ley 8/2011, de 28 de abril, por la que se establecen medidas para la protección de las infraestructuras críticas.
>
> »b) Los servicios digitales que sean mercados en línea, motores de búsqueda en línea y servicios de computación en nube» (art. 2.1, RD 43/2021).

Por tanto, **afecta a los siguientes operadores:**

- Los operadores de servicios esenciales establecidos en España. Recordemos que «la identificación de los servicios esenciales y de los operadores que los presten se efectuará por los órganos y procedimientos previstos por la Ley 8/2011, de 28 de abril, por la que se establecen medidas para la protección de las infraestructuras críticas, y su normativa de desarrollo, en particular el Real Decreto 704/2011, de 20 de mayo, por el que se aprueba el Reglamento de protección de las infraestructuras críticas» (art. 2.2, RD 43/2021), tal y como establece el artículo 6.1 del RD-L 12/2018.

© Universidad Internacional de La Rioja (UNIR)

- «Los proveedores de servicios digitales que tengan su sede social en España y que constituya su establecimiento principal en la Unión Europea, así como los que, no estando establecidos en la Unión Europea, designen en España a su representante en la Unión» (art. 2.2, RD 43/2021).

El artículo 2.3 aclara que **no se aplicará** a:

> «a) Los operadores de redes y servicios de comunicaciones electrónicas y los prestadores de servicios electrónicos de confianza que no sean designados como operadores críticos en virtud de la Ley 8/2011, de 28 de abril.
>
> »b) Los proveedores de servicios digitales cuando se trate de microempresas o pequeñas empresas, de acuerdo con las definiciones recogidas en la Recomendación 2003/361/CE de la Comisión, de 6 de mayo de 2003, sobre la definición de microempresas, pequeñas y medianas empresas» (art. 2.3, RD 43/2021).

En relación con el **marco estratégico e institucional,** señala las autoridades competentes en materia de seguridad de las redes y sistemas de información para los operadores de servicios esenciales que no sean operadores críticos con carácter particular en función del sector al que pertenezcan (art. 3, RD 43/2021).

Se regula la cooperación entre los CSIRT de referencia y entre estos y las autoridades competentes a través de la Plataforma Nacional de Notificación y Seguimiento de Ciberincidentes (art. 4, RD 43/2021).

En los **supuestos de especial gravedad** que requieran un nivel de coordinación superior al necesario en situaciones ordinarias, el CCN-CERT ejercerá la coordinación nacional de la respuesta técnica de los CSIRT (art. 11.2, RD-L 12/2018). El RD 43/2021 nos aclara que estos supuestos de especial gravedad «serán todos aquellos que, atendiendo a la naturaleza de las notificaciones inicial o sucesivas del incidente recibidas por el CSIRT de referencia, posean un impacto o nivel de peligrosidad muy alta o crítica de acuerdo con lo establecido en el anexo, y

© Universidad Internacional de La Rioja (UNIR)

exijan un nivel de coordinación técnica con los otros CSIRT de referencia superior al necesario en situaciones ordinarias» (art. 4.3, RD 43/2021).

El CCN-CERT en los supuestos de especial gravedad y la Oficina de Coordinación de Ciberseguridad del Ministerio del Interior (OCC), cuando las actividades que desarrollen puedan afectar de alguna manera a un operador crítico (art. 11.2, RD-L 12/2018), requerirán al CSIRT de referencia, tras la primera notificación del incidente, al menos la siguiente información:

> «a) Confirmación de que son correctos los datos asignados al incidente, en particular verificando, si existe esta información, la validez de:
>
> »1.o La clasificación del incidente.
>
> »2.o La peligrosidad del incidente.
>
> »3.o El impacto del incidente.
>
> »b) Plan de acción del CSIRT para abordar la resolución técnica del incidente, si procede.
>
> »c) Cualquier información que permita determinar el posible impacto transfronterizo del incidente» (art. 4.4, RD 43/2021).

Requisitos de seguridad

El artículo 6 plasma claramente la **metodología del análisis de riesgos** y formaliza **obligaciones concretas** en materia **de seguridad.** Los operadores de servicios esenciales:

> «deberán aprobar unas políticas de seguridad de las redes y sistemas de información, atendiendo a los principios de seguridad integral, gestión de riesgos, prevención, respuesta y recuperación, líneas de defensa, reevaluación periódica y segregación de tareas.
>
> »Dichas políticas considerarán, como mínimo, los siguientes aspectos:
>
> »a) Análisis y gestión de riesgos.
>
> b) Gestión de riesgos de terceros o proveedores.
>
> c) Catálogo de medidas de seguridad, organizativas, tecnológicas y físicas.

© Universidad Internacional de La Rioja (UNIR)

d) Gestión del personal y profesionalidad.

e) Adquisición de productos o servicios de seguridad.

f) Detección y gestión de incidentes.

g) Planes de recuperación y aseguramiento de la continuidad de las operaciones

h) Mejora continua.

i) Interconexión de sistemas.

j) Registro de la actividad de los usuarios» (art. 6.2, RD 43/2021).

Además, los operadores de servicios esenciales «deberán tener en cuenta, en particular, la dependencia de las redes y sistemas de información y la continuidad de servicios o suministros contratados por el operador, así como las interacciones que presenten con redes y sistemas de información de terceros» (art. 6.3, RD 43/2021).

Las medidas de seguridad adoptadas se formalizarán en una **declaración de aplicabilidad de medidas de seguridad** que deberá ser suscrita por el **responsable de seguridad.** Dicha declaración se incluirá en la **política de seguridad** que apruebe la dirección de la organización. El documento, que deberá remitirse a la autoridad competente respectiva en el plazo de seis meses desde la designación del operador como operador de servicios esenciales, deberá revisarse al menos cada tres años.

Las medidas de seguridad tomarán como referencia las recogidas en el Anexo II del Real Decreto 3/2010, de 8 de enero, por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica, en la medida en que sean aplicables. También podrán tenerse en cuenta otros estándares reconocidos internacionalmente (art. 6.5, RD 43/2021).

En el párrafo séptimo, se establece que en la elaboración de las políticas de seguridad se tendrán en cuenta los **riesgos que se derivan del tratamiento de los datos personales,** de acuerdo con el artículo 24 del RGPD. En caso de que el

© Universidad Internacional de La Rioja (UNIR)

análisis de gestión de riesgos conforme al RGPD exija **medidas adicionales** respecto de las previstas en el Real Decreto 3/2010, se adoptarán las medidas de acuerdo con el artículo 24.1 del RGPD (art. 6.7, RD 43/2021).

Responsable de seguridad

Una novedad introducida por el RD 43/2021 es la formalización de la figura del responsable de seguridad.

«Los operadores de servicios esenciales designarán una persona, unidad u órgano colegiado [en estos dos últimos casos, se deberá designar una persona física representante], responsable de la seguridad de la información que ejercerá las funciones de punto de contacto y coordinación técnica con la autoridad competente y CSIRT de referencia», en el plazo de «tres meses desde su designación como operador de servicios esenciales» (art. 7.1, RD 43/2021).

Las **funciones** del responsable de seguridad son (art. 7.3, RD 43/2021):

- Actuar como punto de contacto con la autoridad competente en materia de supervisión de los requisitos de seguridad de las redes y sistemas de información.

- Actuar como punto de contacto especializado para la coordinación de la gestión de los incidentes con el CSIRT de referencia.

- Remitir a la autoridad competente, a través del CSIRT de referencia y sin dilación

© Universidad Internacional de La Rioja (UNIR)

indebida, las notificaciones de incidentes que tengan efectos perturbadores en la prestación de los servicios a los que se refiere el artículo 19.1 del RD-L 12/2018.

- Elaborar y proponer para aprobación por la organización las políticas de seguridad, que incluirán las medidas técnicas y organizativas, adecuadas y proporcionadas, para gestionar los riesgos que se planteen para la seguridad de las redes y sistemas de información utilizados y para prevenir y reducir al mínimo los efectos de los ciberincidentes que afecten a la organización y los servicios, de conformidad con lo dispuesto en el artículo 6.

- Supervisar y desarrollar la aplicación de las políticas de seguridad, normativas y procedimientos derivados de la organización, supervisar su efectividad y llevar a cabo controles periódicos de seguridad.

- Elaborar la declaración de aplicabilidad de medidas de seguridad.

- Actuar como capacitador de buenas prácticas en seguridad de las redes y sistemas de información, tanto en aspectos físicos como lógicos.

© Universidad Internacional de La Rioja (UNIR)

- Recibir, interpretar y supervisar la aplicación de las instrucciones y guías emanadas de la autoridad competente, tanto para la operativa habitual como para la subsanación de las deficiencias observadas.

- Recopilar, preparar y suministrar información o documentación a la autoridad competente o el CSIRT de referencia, a su solicitud o por propia iniciativa.

Requisitos del responsable de seguridad

La figura del responsable de seguridad debe cumplir con los siguientes requisitos:

> «a) Contar con personal con conocimientos especializados y experiencia en materia de ciberseguridad, desde los puntos de vista organizativo, técnico y jurídico, adecuados al desempeño de las funciones indicadas en el apartado anterior.
>
> »b) Contar con los recursos necesarios para el desarrollo de dichas funciones.
>
> »c) Ostentar una posición en la organización que facilite el desarrollo de sus funciones, participando de forma adecuada y en tiempo oportuno en todas las cuestiones relativas a la seguridad, y manteniendo una comunicación real y efectiva con la alta dirección.
>
> »d) Mantener la debida independencia respecto de los responsables de las redes y los sistemas de información» (art. 7.4, RD 43/2021).

Siempre que se reúnan los requisitos necesarios, la figura será compatible con las señaladas para el responsable de seguridad y enlace y el responsable de seguridad del Esquema Nacional de Seguridad (art. 7.5, RD 43/2021).

Gestión de los incidentes de seguridad (art. 8, RD 43/2021)

Los incidentes deben notificarse, pero, además, deberán gestionarse y resolverse,

© Universidad Internacional de La Rioja (UNIR)

tanto en el caso de que el incidente haya sido detectado por el propio proveedor u operador como si lo ha señalado el CSIRT de referencia.

En el caso de redes y sistemas que no sean propios, los operadores deberán tomar las medidas necesarias para garantizar que dichas acciones se lleven a cabo por los proveedores externos.

Obligaciones de notificación de incidentes de los operadores de servicios esenciales (art. 9, RD 43/2021)

Los operadores de servicios esenciales notificarán a la autoridad competente respectiva, a través del CSIRT de referencia, los incidentes que puedan tener efectos perturbadores significativos en dichos servicios. Se determina el procedimiento de notificación de incidentes mediante una instrucción técnica **(Instrucción nacional de notificación y gestión de ciberincidentes)** incorporada en el Anexo del real decreto y se define tanto la **taxonomía de clasificación (apartado 2 del Anexo)** como la **valoración de impactos (apartado 4 del Anexo),** que establece que los incidentes se asociarán a alguno de los siguientes niveles de impacto: crítico, muy alto, alto, medio, bajo, sin impacto.

Las obligaciones de notificación de violaciones de seguridad a la Agencia Española de Protección de Datos (AEPD) son independientes (art. 33, RGPD).

Procedimientos de notificación de incidentes

> «1. Los CSIRT de referencia garantizarán un intercambio fluido de información con las autoridades competentes que correspondan, asegurando el adecuado seguimiento durante la gestión de los incidentes.
>
> »2. Los operadores de servicios esenciales realizarán las notificaciones a través del responsable de la seguridad de la información designado» (art. 10, RD 43/2021).

La primera notificación se realizará en cuanto se disponga de información para

© Universidad Internacional de La Rioja (UNIR)

determinar que se dan las circunstancias para la notificación, siguiendo los umbrales temporales establecidos en la instrucción técnica (art. 10.3, RD 43/2021).

Para actualizar o completar dicha información, se realizarán notificaciones intermedias, y una notificación final tras su resolución «informando del detalle de la evolución del suceso, la valoración de la probabilidad de su repetición, y las medidas correctoras que eventualmente tenga previsto adoptar el operador» (art. 10.3, RD 43/2021).

Nivel de peligrosidad o impacto	Notificación inicial	Notificación intermedia	Notificación final
Crítico	Inmediata	24/48 horas	20 días
Muy alto	Inmediata	72 horas	40 días
Alto	Inmediata	-	-
Medio	-	-	-
Bajo	-	-	-

Tabla 1. Ventana temporal de reporte. Fuente: elaborado a partir de RD 43/2021.

«Los tiempos reflejados en la tabla [1] para la "notificación intermedia" y la "notificación final" tienen como referencia el momento de remisión de la "notificación inicial". La "notificación inicial" tiene como referencia de tiempo el momento de tener conocimiento del incidente» (Anexo, RD 43/2021).

«Lo establecido en los apartados anteriores será de aplicación a los proveedores de servicios digitales en tanto que no se regule de modo diferente en los actos de ejecución previstos en el artículo 16.9 de la Directiva (UE) 2016/1148 del Parlamento Europeo y del Consejo, de 6 de julio de 2016, relativa a las medidas destinadas a garantizar un elevado nivel común de seguridad de las redes y sistemas de

© Universidad Internacional de La Rioja (UNIR)

información en la Unión» (art. 10.5, RD 43/2021).

El CSIRT de referencia, en colaboración con la autoridad competente, valorará con prontitud la información que reciba «con vistas a determinar si el incidente puede tener efectos perturbadores significativos para los servicios esenciales prestados en otros Estados miembros», así como la información recibida por parte de otros Estados miembros para evaluar su impacto en los operadores de servicios esenciales de nuestro país (art. 10.6, RD 43/2021).

© Universidad Internacional de La Rioja (UNIR)

3.5. Nuevo paquete de ciberseguridad de la Unión Europea

En diciembre de 2020, la Comisión Europea y el Alto representante de la UE para asuntos exteriores y política de seguridad presentaron un nuevo paquete de medidas de ciberseguridad cuyo elemento principal es la **nueva Estrategia de Ciberseguridad de la UE para la Década Digital** (Comunicación JOIN/2020/18 final).



Figura 1. Nueva Estrategia de Ciberseguridad de la UE para la Década Digital. Fuente: Comisión Europea, 2021a.

Se afirma que:

> «la nueva Estrategia de Ciberseguridad de la UE para la Década Digital constituye un componente clave de la configuración del futuro digital de Europa, el Plan de Recuperación de la Comisión para Europa, la Estrategia para una Unión de la Seguridad 2020-2025, la Estrategia Global para la Política Exterior y de Seguridad de la UE y la Agenda Estratégica del Consejo Europeo 2019-2024. En ella se establece la forma en que la UE protegerá a su población, empresas e instituciones de las ciberamenazas, y la forma en que fomentará la cooperación internacional y tomará la iniciativa para asegurar una internet mundial y abierta» (Comisión Europea, 2020, I).

Se concluye que «la UE debería impulsar estándares y normas para conseguir

© Universidad Internacional de La Rioja (UNIR)

soluciones de categoría mundial y normas de ciberseguridad aplicables a servicios esenciales e infraestructuras básicas, así como desarrollar y aplicar nuevas tecnologías. Todos los usos de Internet a nivel individual y de organización forman parte de la solución para garantizar una transformación digital segura» (Comisión Europea, 2020, IV).

Se trata de una estrategia ambiciosa cuyo contenido analizamos a continuación. La comunicación se divide en tres apartados:

- I. Introducción: una transformación digital cibersegura en un entorno complejo de amenazas.
- II. Pensar a nivel mundial, actuar a nivel europeo.
- III. La ciberseguridad en las instituciones, agencias y organismos europeos.

En el primer apartado, la Comisión Europea afirma que «la ciberseguridad es esencial para construir una Europa resiliente, ecológica y digital» (2020, I), ya que es consciente de que los grandes servicios son cada vez más dependientes de las redes y sistemas de información. Por otro lado, los dispositivos conectados superan al número de personas en el planeta, la industria cada vez está más digitalizada y conectada y a las amenazas existentes debe sumarse el entorno de tensión geopolítica respecto a Internet y las tecnologías.

La Comisión Europea pone de relieve que «la UE carece de una conciencia colectiva de la situación de las amenazas cibernéticas. Esto se debe a que las autoridades nacionales no reúnen ni comparten sistemáticamente información —como la disponible en el sector privado— que pueda ayudar a evaluar el estado de la ciberseguridad en la UE» (2020, I).

En el segundo apartado, se analizan los tres ámbitos de actuación de la UE en los que se enmarcan las propuestas concretas de esta estrategia de ciberseguridad de la UE:

© Universidad Internacional de La Rioja (UNIR)

- 1. Resiliencia, soberanía tecnológica y liderazgo.
- 1.1. Infraestructura resiliente y servicios críticos.

La Comisión propone una **nueva directiva sobre la seguridad de las redes y los sistemas de información (la actual Directiva NIS 2)** con el objeto de aumentar la ciberresiliencia tanto del sector público como privado y de armonizar aspectos tales como el ámbito de aplicación, requisitos de seguridad, notificación de incidentes, supervisión y cumplimiento nacionales y capacidades de las autoridades competentes. También propone revisar la normativa sobre resiliencia de las infraestructuras críticas (actual Directiva (UE) 2022/2557 del Parlamento Europeo y del Consejo de 14 de diciembre de 2022 relativa a la resiliencia de las entidades críticas y por la que se deroga la Directiva 2008/114/CE del Consejo).

- 1.2. Construir un escudo cibernético europeo.
- 1.3. Una infraestructura de comunicación ultrasegura.
- 1.4. Protección de la próxima generación de redes móviles de banda ancha.
- 1.5. Una internet de las cosas seguras.
- 1.6. Mayor seguridad mundial en internet.
- 1.7. Una presencia reforzada en la cadena de suministro de tecnología.
- 1.8. Una población activa cibercualificada de la UE.
- 2. Desarrollo de la capacidad operativa para prevenir, disuadir y contrarrestar.
- 2.1. Una unidad informática conjunta.
- 2.2. Lucha contra la ciberdelincuencia.
- 2.3. Conjunto de instrumentos de ciberdiplomacia de la UE.

© Universidad Internacional de La Rioja (UNIR)

- 2.4. Impulsar las capacidades de ciberdefensa.
- 3. Fomentar un ciberespacio mundial y abierto.
- 3.1. Liderazgo de la UE en materia de estándares, normas y marcos en el ciberespacio.
- 3.2. Cooperación con los socios y la comunidad de múltiples partes interesadas.
- 3.3. Fortalecimiento de las capacidades globales para aumentar la capacidad de recuperación mundial.

En el tercer apartado se concluye que son necesarias normas coherentes y homogéneas para mejorar el nivel global de seguridad. Para ello se prevé aprobar un reglamento sobre la seguridad de la información en los organismos y agencias de las instituciones de la UE y otro reglamento relativo a las normas de ciberseguridad comunes para las instituciones y organismos de la UE. También se prevé reforzar las capacidades del CERT-UE (Comisión Europea, 2020, III).

La Comisión Europea y el Alto representante desarrollarán criterios para la evaluación del progreso de la esta estrategia y lo supervisarán.

© Universidad Internacional de La Rioja (UNIR)

3.6. Directiva (UE) 2022/2555 relativa a las medidas destinadas a garantizar un elevado nivel común de ciberseguridad en toda la Unión (Directiva NIS 2)

La directiva relativa a las medidas destinadas a garantizar un elevado nivel común de ciberseguridad y por la que se deroga la Directiva (UE) 2016/1148, conocida como **Directiva NIS 2,** actualiza las deficiencias que ha puesto de manifiesto la Directiva NIS ante los nuevos retos fruto de la transformación digital de la sociedad.

Entre sus novedades, encontramos las siguientes.

Ampliación del ámbito de aplicación

Se introducen nuevos sectores y también un límite de tamaño, de modo que todas las empresas medianas y grandes de tales sectores quedan incluidas en su ámbito de aplicación.

Las entidades incluidas en el ámbito de aplicación de la Directiva a efectos del cumplimiento de las medidas para la gestión de riesgos de ciberseguridad deben clasificarse en dos categorías, **entidades esenciales y entidades importantes**, en función del grado de criticidad de sus sectores o del tipo de servicio que prestan, así como de su tamaño (Considerando 15).

En el Anexo I («Sectores de alta criticidad») se incluyen las **entidades esenciales** (sectores de energía, transporte, banca, infraestructuras de los mercados financieros, sanitario, agua potable, aguas residuales, infraestructura digital, Administración pública y espacio) y en el Anexo II («Otros sectores críticos»), **entidades importantes** (sector de servicios postales y de mensajería; gestión de residuos; fabricación, producción y distribución de sustancias y mezclas químicas; producción, transformación y distribución de alimentos; proveedores de servicios digitales; y

© Universidad Internacional de La Rioja (UNIR)

determinados subsectores del sector de fabricación).

El artículo 3 de la Directiva establece que se considerarán entidades esenciales:

> «a) entidades de alguno de los tipos mencionados en el anexo I que superen los límites máximos previstos en el artículo 2, apartado 1, del anexo de la Recomendación 2003/361/CE para las medianas empresas;
>
> b) prestadores cualificados de servicios de confianza y registros de nombres de dominio de primer nivel, así como proveedores de servicios de DNS, independientemente de su tamaño;
>
> c) proveedores de redes públicas de comunicaciones electrónicas o de servicios de comunicaciones electrónicas disponibles para el público que sean consideradas medianas empresas con arreglo al artículo 2 del anexo de la Recomendación 2003/361/CE;
>
> d) entidades de la Administración pública a que se refiere el artículo 2, apartado 2, letra f) inciso i);
>
> e) cualquier otra entidad de uno de los tipos mencionados en los anexos I o II que un Estado miembro identifique como entidad esencial en virtud del artículo 2, apartado 2, letras b) a e);
>
> f) entidades identificadas como entidades críticas con arreglo a la Directiva (UE) 2022/2557 a que se refiere el artículo 2, apartado 3, letra f), de la presente Directiva;
>
> g) si así lo dispone el Estado miembro, las entidades identificadas por dicho Estado miembro antes del 16 de enero de 2023 como operadores de servicios esenciales de conformidad con la Directiva (UE) 2016/1148 o el Derecho nacional».

Con respecto a las **entidades importantes**, el párrafo segundo del artículo 3 establece que se considerarán «todas las entidades de uno de los tipos mencionados en los anexos I o II que no puedan considerarse entidades esenciales con arreglo al apartado 1 del presente artículo (…)».

Respecto a las empresas más pequeñas, se deja margen de actuación a los Estados miembros para que valoren si suponen un alto riesgo para la seguridad.

Vemos, por tanto, cómo se incluyen sectores que hasta la fecha no entraban dentro

© Universidad Internacional de La Rioja (UNIR)

del ámbito de aplicación de la Directiva anterior por no ser considerados críticos, como, por ejemplo, el sector postal o el sector alimentario y los proveedores de servicios digitales.

Eliminación de la distinción entre operadores de servicios esenciales y proveedores de servicios digitales

El Considerando 6 afirma que «Con la derogación de la Directiva (UE) 2016/1148, es preciso ampliar el ámbito de aplicación por sectores a una parte más extensa de la economía para ofrecer una cobertura completa de los sectores y servicios de vital importancia para las actividades sociales y económicas fundamentales dentro del mercado interior. En particular, la presente Directiva pretende tratar de superar las deficiencias de la diferenciación entre operadores de servicios esenciales y proveedores de servicios digitales, que ha quedado demostrado que es obsoleta al no reflejar la importancia de los sectores o servicios para las actividades sociales y económicas en el mercado interior» (Cdo. 6, Dir. NIS 2). Se propone que la clasificación se haga en función de su importancia, tal y como se ha explicado en el apartado anterior.

Gestión de riesgos

El artículo 21 establece que:

> «1. Los Estados miembros velarán por que las **entidades esenciales e importantes tomen las medidas técnicas, operativas y de organización adecuadas y proporcionadas** para gestionar los riesgos que se planteen para la seguridad de los sistemas de redes y de información que utilizan dichas entidades en sus operaciones o en la prestación de sus servicios y prevenir o minimizar las repercusiones de los incidentes en los destinatarios de sus servicios y en otros servicios.
>
> Teniendo en cuenta la situación y, en su caso, las normas europeas e internacionales pertinentes, así como el coste de su aplicación, las medidas a que se refiere el párrafo primero **garantizarán un nivel de seguridad** de los sistemas de redes y de información adecuado en relación con los riesgos planteados. Al evaluar la proporcionalidad de dichas medidas, se tendrá debidamente en cuenta el grado de exposición de la entidad a los riesgos, el tamaño de la entidad y la probabilidad de que se produzcan incidentes y su

© Universidad Internacional de La Rioja (UNIR)

gravedad, incluidas sus repercusiones sociales y económicas

»2. Las medidas a que se hace referencia en el apartado 1 se fundamentarán en un enfoque basado en todos los peligros que tenga por objeto proteger los sistemas de redes y de información y el entorno físico de dichos sistemas frente a incidentes, e incluirán al menos los siguientes elementos:

»a) las políticas de seguridad de los sistemas de información y **análisis de riesgos**;

»b) la gestión de incidentes;

»c) la continuidad de las actividades, como la gestión de copias de seguridad y la recuperación en caso de catástrofe, y la gestión de crisis;

»d) la seguridad de la cadena de suministro, incluidos los aspectos de seguridad relativos a las relaciones entre cada entidad y sus proveedores o prestadores de servicios directos;

»e) la seguridad en la adquisición, el desarrollo y el mantenimiento de sistemas de redes y de información, incluida la gestión y divulgación de las vulnerabilidades;

»f) las políticas y los procedimientos para evaluar la eficacia de las medidas para la gestión de riesgos de ciberseguridad;

»g) las prácticas básicas de ciberhigiene y formación en ciberseguridad;

» h) las políticas y procedimientos relativos a la utilización de criptografía y, en su caso, de cifrado;

» i) la seguridad de los recursos humanos, las políticas de control de acceso y la gestión de activos;

» j) el uso de soluciones de autenticación multifactorial o de autenticación continua, comunicaciones de voz, vídeo y texto seguras y sistemas seguros de comunicaciones de emergencia en la entidad, cuando proceda (…)» (art. 18, Dir. NIS 2).

Procedimiento de notificación de incidentes

El artículo 23 regula las obligaciones de notificación y establece que:

«Cada Estado miembro velará por que las entidades esenciales e importantes notifiquen, sin demora indebida, a su CSIRT o, en su caso, a su autoridad competente de conformidad con el apartado 4 **cualquier incidente que tenga un impacto significativo** en la prestación de sus servicios según se contempla en el apartado 3 (incidente

© Universidad Internacional de La Rioja (UNIR)

significativo). Cuando proceda, las entidades afectadas notificarán, sin demora indebida, a los **destinatarios de sus servicios** los incidentes significativos susceptibles de afectar negativamente a la prestación de dichos servicios. Cada Estado miembro garantizará que dichas entidades notifiquen, entre otros detalles, cualquier información que permita al CSIRT o, en su caso, a la autoridad competente determinar las repercusiones transfronterizas del incidente. El mero acto de notificar no elevará la responsabilidad de la entidad notificante.

Cuando las entidades afectadas notifiquen a la autoridad competente un incidente significativo con arreglo al párrafo primero, el Estado miembro velará por que dicha autoridad competente transmita la notificación al CSIRT en el momento de su recepción.

En caso de un incidente significativo transfronterizo o intersectorial, los Estados miembros velarán por que se facilite a sus puntos de contacto únicos, a su debido tiempo, la información pertinente notificada de conformidad con el apartado 4.» (art. 23.1, Dir. NIS 2).

En el tercer párrafo nos aclara qué se entiende por **incidente con impacto significativo:**

«a) sin demora indebida y, en cualquier caso, en el plazo de veinticuatro horas desde que se haya tenido constancia del incidente significativo, una alerta temprana en la que se indicará, cuando proceda, si cabe sospechar que el incidente significativo responde a una acción ilícita o malintencionada o puede tener repercusiones transfronterizas;

b) sin demora indebida y, en cualquier caso, en el plazo de setenta y dos horas desde que se haya tenido constancia del incidente significativo, una notificación del incidente en la que se actualizará, cuando proceda, la información contemplada en la letra a) y se expondrá una evaluación inicial del incidente significativo, incluyendo su gravedad e impacto, así como indicadores de compromiso, cuando estén disponibles» (art. 23.4, Dir. NIS 2).

Una vez notificado el incidente:

«c) a instancias de un CSIRT o, en su caso, de la autoridad competente, un **informe intermedio** con las actualizaciones pertinentes sobre la situación;

d) un informe final, a más tardar **un mes después de presentar la notificación del incidente** contemplada en la letra b), en el que se recojan los siguientes elementos:

i) una descripción detallada del incidente, incluyendo su gravedad e impacto;

© Universidad Internacional de La Rioja (UNIR)

> ii) el tipo de amenaza o causa principal que probablemente haya desencadenado el incidente;
>
> iii) las medidas paliativas aplicadas y en curso;
>
> iv) cuando proceda, las repercusiones transfronterizas del incidente;
>
> e) en el caso de que el incidente siga en curso en el momento de la presentación del informe final contemplado en la letra d), los Estados miembros velarán por que las entidades afectadas presenten un informe de situación en ese momento y un informe final en el **plazo de un mes a partir de que hayan gestionado el incidente**».

Refuerzo de la seguridad de las cadenas de suministro críticas

El Grupo de Cooperación, en colaboración con la Comisión y la ENISA, y, en su caso, previa consulta a las partes interesadas pertinentes, incluidas las pertenecientes a la industria, debe llevar a cabo **evaluaciones coordinadas de los riesgos de seguridad de las cadenas de suministro críticas**. Así lo establecen el Considerando 90, el artículo 14.4 i) y el art 22).

El Considerando 91 nos aclara que:

> «A fin de identificar las cadenas de suministro que deben ser objeto de una evaluación coordinada de riesgos, han de tenerse en cuenta los siguientes criterios: i) la medida en que las entidades esenciales e importantes utilizan servicios, sistemas o productos de TIC críticos y dependen de ellos; ii) la importancia de servicios, sistemas o productos de TIC críticos específicos para desempeñar funciones críticas o sensibles, en particular el tratamiento de datos personales; iii) la disponibilidad de servicios, sistemas o productos de TIC alternativos; iv) la resiliencia de la cadena de suministro global de servicios, sistemas o productos de TIC a lo largo de su ciclo de vida frente a las perturbaciones; y v) en el caso de los servicios, sistemas o productos de TIC emergentes, la importancia que puedan tener en el futuro para las actividades de las entidades. Además, debe prestarse especial atención a los servicios, sistemas o productos de TIC que proceden de terceros países y están sujetos a requisitos específicos» (cdo. 91, Dir. NIS 2).

El artículo 22 establece que «La Comisión, tras consultar al Grupo de Cooperación y a la ENISA, y, en caso necesario, con las partes interesadas pertinentes, delimitará los servicios, sistemas o productos de TIC críticos específicos que podrán ser objeto

© Universidad Internacional de La Rioja (UNIR)

de la evaluación coordinada de riesgos de seguridad» (art. 22.2, Dir. NIS 2).

Supervisión y sanciones

Las **autoridades nacionales** aplicarán medidas de supervisión más rigurosas. Así, respecto a las medidas de supervisión:

> «(…) las entidades esenciales deben estar sujetas a un régimen de supervisión completo (a priori y a posteriori), mientras que las entidades importantes deben estar sujetas a un régimen de supervisión menos estricto exclusivamente a posteriori. Por lo tanto, las entidades importantes no deben tener la obligación de documentar sistemáticamente la conformidad con las medidas para la gestión de riesgos de ciberseguridad a la vez que las autoridades competentes deben aplicar un enfoque reactivo a posteriori respecto a la supervisión y, por ende, no tienen la obligación general de supervisar a dichas entidades (…)» (Cdo. 122, Dir. NIS 2).

Se relacionan en el artículo 32 las medidas de supervisión y ejecución relativas a entidades esenciales, tales como inspecciones *in situ* y supervisión a distancia, auditorías de seguridad periódicas y específicas, etc.

Las autoridades competentes de cada estado miembro tendrán competencia para apercibir o requerir que se adopten las medidas necesarias para garantizar que las medidas para la gestión de riesgos de ciberseguridad son conformes, así como para fijar un plazo en el que se requerirá a la entidad esencial que adopte las medidas necesarias para subsanar las deficiencias o cumplir los requisitos de dichas autoridades. Si las medidas requeridas no se adoptasen en el plazo establecido, las autoridades competentes estén facultadas para:

> «a) suspender temporalmente o solicitar a un organismo de certificación o autorización o a un órgano jurisdiccional, de conformidad con el Derecho nacional, que suspenda temporalmente una certificación o autorización referente a una parte o la totalidad de los servicios o actividades de que se trate prestados por la entidad esencial;
>
> b) solicitar que los organismos o los órganos jurisdiccionales competentes de acuerdo con el Derecho nacional prohíban temporalmente a cualquier persona que ejerza responsabilidades de dirección a nivel de director general o representante legal en dicha

© Universidad Internacional de La Rioja (UNIR)

entidad esencial ejercer funciones de dirección en dicha entidad» (Art 32.5).

En relación con las sanciones, los Estados miembros establecerán el régimen de sanciones aplicables a cualquier incumplimiento de las disposiciones nacionales adoptadas al amparo de la presente Directiva y adoptarán todas las medidas necesarias para garantizar su ejecución.

No obstante, en la Directiva se establecen cantidades máximas distinguiendo:

- Las **entidades esenciales** sancionadas por el incumplimiento de los artículos 21 o 23, con multas administrativas de un máximo de, al menos, 10 000 000 EUR o de un máximo de, al menos, el 2 % del volumen de negocios anual total a nivel mundial de la empresa a la que pertenece la entidad esencial durante el ejercicio financiero anterior, optándose por la de mayor cuantía.

- Las **entidades importantes** sancionadas por el incumplimiento de los artículos 21 o 23, con multas administrativas de un máximo de, al menos, 7 000 000 EUR o de un máximo de, al menos, el 1,4 % del volumen de negocios anual total a nivel mundial de la empresa a la que pertenece la entidad importante durante el ejercicio financiero anterior, optándose por la de mayor cuantía (art. 34, 4 y 5).

Intercambio de información y cooperación entre los Estados miembros

Se refuerza el grupo de cooperación: «se establece un Grupo de Cooperación a fin de apoyar y facilitar la cooperación estratégica y el intercambio de información entre los Estados miembros y para fortalecer la confianza y la colaboración» (art. 14.1, Dir. NIS 2). Estará formado por representantes de los Estados miembros,

© Universidad Internacional de La Rioja (UNIR)

la Comisión y la ENISA.

El cuarto párrafo del artículo 14 nos concreta sus tareas:

> «a) proporcionar orientación a las autoridades competentes en relación con la transposición y aplicación de la presente Directiva;
>
> »b) proporcionar orientación a las autoridades competentes en relación con el desarrollo y la ejecución de políticas sobre divulgación coordinada de vulnerabilidades a que se refiere el artículo 7, apartado 2, letra c);
>
> »c) intercambiar buenas prácticas e información en relación con la aplicación de la presente Directiva, también por lo que respecta a las ciberamenazas, los incidentes, las vulnerabilidades, los cuasiincidentes, las iniciativas de concienciación, la formación, los ejercicios y las habilidades, el desarrollo de capacidades, las normas y especificaciones técnicas, así como la identificación de entidades esenciales e importantes en virtud del artículo 2, apartado 2, letras b) a e);;
>
> »d) intercambiar recomendaciones y cooperar con la Comisión en iniciativas políticas sobre aspectos emergentes de la ciberseguridad y la coherencia general de los requisitos sectoriales en este ámbito;;
>
> »e) intercambiar recomendaciones y cooperar con la Comisión en la redacción de los actos delegados o de ejecución que adopte en virtud de la presente Directiva;
>
> »f) intercambiar buenas prácticas e información con las instituciones, los órganos y los organismos de la Unión pertinentes;
>
> »g) intercambiar puntos de vista sobre la aplicación de los actos jurídicos sectoriales de la Unión que contienen disposiciones sobre ciberseguridad
>
> »h) si procede, analizar los informes sobre la revisión interpares a que se refiere el artículo 19, apartado 9 y extraer conclusiones y recomendaciones;;
>
> »i) llevar a cabo evaluaciones coordinadas de los riesgos de seguridad de las cadenas de suministro críticas de conformidad con el artículo 22, apartado 1;
>
> »j) analizar casos de asistencia mutua, incluidas las experiencias y los resultados de las acciones transfronterizas de supervisión conjuntas a que se refiere el artículo 37;
>
> »k) a petición de uno o varios Estados miembros afectados, debatir las solicitudes específicas de asistencia mutua a que se refiere el artículo 37
>
> »l) proporcionar orientación estratégica a la red de CSIRT y a EU-CyCLONe sobre

© Universidad Internacional de La Rioja (UNIR)

cuestiones emergentes específicas;

»m) intercambiar puntos de vista sobre la política relativa a las acciones de seguimiento tras incidentes y crisis de ciberseguridad a gran escala sobre la base de las lecciones extraídas de la red CSIRT y la EU-CyCLONe»

»n) contribuir a las capacidades de ciberseguridad de toda la Unión facilitando el intercambio de funcionarios nacionales a través de un programa de desarrollo de capacidades en el que participe el personal de las autoridades competentes o los CSIRT;

»o) organizar reuniones conjuntas periódicas con las partes interesadas privadas pertinentes de toda la Unión para debatir las actividades realizadas por el Grupo de Cooperación y recabar apreciaciones sobre los desafíos políticos emergentes;

»p) debatir sobre las labores realizadas en relación con los ejercicios de ciberseguridad, incluida la labor efectuada por la ENISA;

»q) establecer la metodología y los aspectos organizativos de las revisiones interpares a que se refiere el artículo 19, apartado 5, así como establecer la metodología de autoevaluación para los Estados miembros de conformidad con el artículo 19, apartado 5, con la ayuda de la Comisión y de la ENISA y, en cooperación con la Comisión y la ENISA, elaborar códigos de conducta que respalden los métodos de trabajo de los expertos en ciberseguridad designados de conformidad con el artículo 19, apartado 6;

»r) preparar informes a efectos de la revisión que contempla el artículo 40 sobre la experiencia adquirida a nivel estratégico y con las revisiones interpares;

»s) debatir y llevar a cabo una evaluación periódica de la situación de las ciberamenazas o incidentes, como los programas de secuestro» (art. 14.4, Dir. NIS 2).

Divulgación coordinada de vulnerabilidades

El considerando 58 establece que:

«La divulgación coordinada de las vulnerabilidades se refiere específicamente a un proceso estructurado a través del cual las vulnerabilidades se notifican al fabricante o proveedor de los productos o servicios de TIC potencialmente vulnerables de manera que este pueda diagnosticar y subsanar las vulnerabilidades antes de que se divulgue información detallada a terceros o al público. Asimismo, la divulgación coordinada de las vulnerabilidades debe también comprender la coordinación entre la persona física o jurídica notificante y el fabricante o proveedor de los productos o servicios de TIC potencialmente vulnerables en lo tocante al momento de la subsanación y la publicación

© Universidad Internacional de La Rioja (UNIR)

de las vulnerabilidades» (cdo. 58, Dir. NIS 2).

Así, el artículo 12.1 establece que:

> «Cada Estado miembros designará a uno de sus CSIRT como coordinador a efectos de la divulgación coordinada de las vulnerabilidades. El CSIRT designado como coordinador ejercerá de intermediario de confianza y facilitará, cuando sea necesario, la interacción entre la persona física o jurídica que notifique una vulnerabilidad y el fabricante o proveedor de los productos de TIC o los servicios de TIC potencialmente vulnerables, a petición de cualquiera de las partes. Cuando la vulnerabilidad notificada afecte a varios fabricantes o proveedores de productos o servicios de TIC de la Unión, el CSIRT designado de cada Estado miembro afectado cooperará con la red de CSIRT» (art. 12.1, Dir. NIS 2).

Además, la ENISA desarrollará y mantendrá una base de datos europea de vulnerabilidades (art. 12.2, Dir. NIS 2).

Responsabilidad del cumplimiento (art 20)

Los **órganos de dirección** de las entidades esenciales e importantes deberán aprobar las medidas para la gestión de riesgos de ciberseguridad, supervisar su puesta en práctica y responder por el incumplimiento por parte de las entidades de dichas obligaciones.

La Directiva no define qué se entiende por órganos de dirección, por lo que no queda claro si las responsabilidades se exigirán a nivel de los órganos de administración de la compañía o bien de los cargos responsables de la dirección y gestión de operaciones.

Cuando una entidad constate que no cumple las medidas para la gestión de riesgos de ciberseguridad deberá adoptar, sin demora indebida, todas las medidas correctoras apropiadas y proporcionadas necesarias, lo cual implica la exigencia de responsabilidades a los órganos de dirección en caso de no hacerlo.

Obligación de formación

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Se establece la obligación de que los miembros de los órganos de dirección de las entidades esenciales e importantes asistan a formaciones. Asimismo, se alentará a estas entidades para que ofrezcan formaciones similares a sus empleados periódicamente al objeto de adquirir conocimientos y destrezas suficientes que les permitan detectar riesgos y evaluar las prácticas de gestión de riesgos de ciberseguridad y su repercusión en los servicios proporcionados por la entidad (Art 20.2 Directiva NIS 2).

© Universidad Internacional de La Rioja (UNIR)

3.7. Directiva (UE) 2022/2557 del Parlamento Europeo y del Consejo de 14 de diciembre de 2022 relativa a la resiliencia de las entidades críticas

Esta directiva deroga la Directiva 2008/114/CE del Consejo, de 8 de diciembre de 2008, sobre la identificación y designación de infraestructuras críticas europeas y la evaluación de la necesidad de mejorar su protección.

Esta directiva se propuso junto con la propuesta de la actual Directiva NIS 2, dado que tras una evaluación en 2019 de la directiva de 2008 se evidenció la necesidad de actualizar y reforzar la normativa en relación con la resiliencia de las entidades críticas.

El Consejo de la Unión Europea aprobó una **recomendación**, acto no vinculante, que pone de manifiesto la voluntad política de los Estados miembros de cooperar y su compromiso con «una serie de acciones específicas a escala nacional y de la Unión destinadas a apoyar y mejorar la resiliencia de las infraestructuras críticas, de carácter voluntario, que se centran en las infraestructuras críticas que tienen una importancia transfronteriza significativa y en sectores clave identificados, como la energía, las infraestructuras digitales, el transporte y el espacio» (capítulo I).

Tal y como se pone de manifiesto en el Considerando 3 de la Recomendación:

> «Si bien la responsabilidad principal de garantizar la seguridad y la prestación de servicios esenciales a través de infraestructuras críticas corresponde a los Estados miembros y a los operadores de sus infraestructuras críticas, una mayor coordinación a escala de la Unión es adecuada especialmente a la luz de amenazas cambiantes que pueden afectar a varios Estados miembros a la vez, como la guerra de agresión rusa contra Ucrania y las campañas híbridas contra los Estados miembros, o afectar a la resiliencia y el buen funcionamiento de la economía, el mercado único y la sociedad de la Unión en su conjunto. Debe prestarse especial atención a las infraestructuras críticas situadas fuera del territorio de los Estados miembros, como las infraestructuras críticas

© Universidad Internacional de La Rioja (UNIR)

submarinas o las infraestructuras energéticas en alta mar».

Tal y como se afirma en el Considerando 9 de la Directiva sobre resiliencia de las entidades críticas:

> «Dada la importancia de la ciberseguridad para la resiliencia de las entidades críticas y en aras de la coherencia, debe garantizarse, siempre que sea posible, un enfoque coherente entre la presente Directiva y la Directiva (UE) 2022/2555 (NIS 2) (…) Dado que la ciberseguridad se trata de manera suficiente en la Directiva (UE) 2022/2555, las materias reguladas por dicha Directiva deben quedar excluidas del ámbito de aplicación de la presente Directiva, sin perjuicio del régimen particular aplicable a las entidades del sector de las infraestructuras digitales».

Así, el artículo 1.2 de la Directiva v2022/2557 establece:

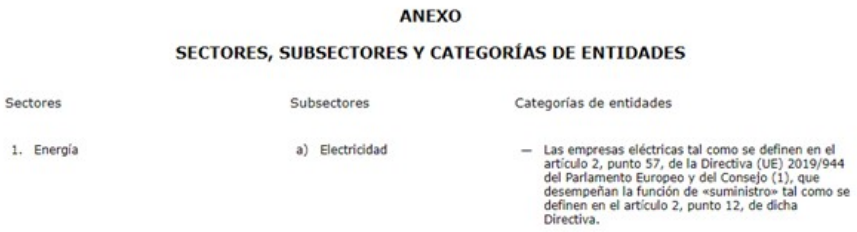
> «La presente Directiva no se aplicará a las materias reguladas por la Directiva (UE) 2022/2555, sin perjuicio de lo dispuesto en el artículo 8 de la presente Directiva. Habida cuenta de la relación entre la seguridad física y la ciberseguridad de las entidades críticas, los Estados miembros garantizarán que la presente Directiva y la Directiva (UE) 2022/2555 se apliquen de manera coordinada».

La Directiva define **entidad crítica** como «una entidad pública o privada identificada por un Estado miembro de conformidad con el artículo 6 como perteneciente a una de las categorías establecidas en la tercera columna del cuadro del anexo» (artículo 2).

En el artículo 6 se establece que, a más tardar, el 17 de julio de 2026 los Estados miembros identificarán las entidades críticas para los sectores y subsectores indicados en el anexo.

Por ejemplo:

© Universidad Internacional de La Rioja (UNIR)



ANEXO

SECTORES, SUBSECTORES Y CATEGORÍAS DE ENTIDADES

Sectores	Subsectores	Categorías de entidades
1. Energía	a) Electricidad	— Las empresas eléctricas tal como se definen en el artículo 2, punto 57, de la Directiva (UE) 2019/944 del Parlamento Europeo y del Consejo (1), que desempeñan la función de «suministro» tal como se definen en el artículo 2, punto 12, de dicha Directiva.

Figura 2. Anexo de la Directiva v2022/2557.

Asimismo, los Estados miembros, a la hora de identificar entidades críticas, tendrán en cuenta los resultados de su evaluación de riesgos del Estado miembro y su estrategia. Aplicarán todos los criterios siguientes:

> «a) la entidad presta uno o más servicios esenciales;
>
> b) la entidad opera en el territorio de dicho Estado miembro y su infraestructura crítica está situada en él, y
>
> c) un incidente tendría efectos perturbadores significativos, determinados de conformidad con el artículo 7, apartado 1, en la prestación por la entidad de uno o más servicios esenciales, o en la prestación de otros servicios esenciales en los sectores indicados en el anexo que dependen de dicho o dichos servicios esenciales» (artículo 6.2).

También define en su artículo 2:

> «3) «incidente»: un acontecimiento que tiene el potencial de perturbar significativamente, o que perturbe, la prestación de un servicio esencial, en particular cuando afecte a los sistemas nacionales que salvaguardan el Estado de Derecho;
>
> 4) «infraestructura crítica»: un elemento, instalación, equipo, red o sistema, o parte de un elemento, instalación, equipo, red o sistema, que es necesario para la prestación de un servicio esencial;
>
> 5) «servicio esencial»: un servicio que es crucial para el mantenimiento de funciones sociales vitales, las actividades económicas, la salud pública y la seguridad, o el medio ambiente;»

Evaluación de riesgos por parte de las entidades críticas

Las entidades críticas deberán realizar una evaluación de riesgos en el plazo de

© Universidad Internacional de La Rioja (UNIR)

nueve meses desde la notificación (un mes desde su identificación como entidades críticas) y, posteriormente, siempre que sea necesario y como mínimo cada cuatro años (artículo 12).

Notificación de incidentes

Las entidades críticas notificarán sin demora indebida a la autoridad competente los incidentes que perturben o puedan perturbar de forma significativa la prestación de servicios esenciales. Deberá notificarse en un plazo de veinticuatro horas a partir del momento en que tengan conocimiento de un incidente, una notificación inicial seguida, en su caso, de un informe detallado en el plazo de un mes, a más tardar (artículo 15).

© Universidad Internacional de La Rioja (UNIR)

3.8. Reglamento de Ciberseguridad de la UE

El Reglamento (UE) 2019/881 del Parlamento Europeo y del Consejo de 17 de abril de 2019 relativo a ENISA (Agencia de la Unión Europea para la Ciberseguridad) y a la certificación de la ciberseguridad de las tecnologías de la información y la comunicación y por el que se deroga el Reglamento (UE) n.o 526/2013 tiene dos objetivos:

- Establecer los objetivos, las tareas y los aspectos organizativos relativos a **ENISA**.
- Establecer un **marco europeo de certificación de la ciberseguridad**, a efectos de garantizar un nivel adecuado de ciberseguridad de los productos, servicios y procesos de TIC en la Unión y evitar la fragmentación del mercado interior respecto a los esquemas de certificación de la ciberseguridad en la Unión (artículo 1.1).

ENISA

Entre otros objetivos de ENISA, el artículo 4 incluye:

- Ser un centro de conocimientos técnicos sobre ciberseguridad en virtud de su independencia, la calidad científica y técnica del asesoramiento y la asistencia e información ofrecidas, la transparencia de sus procedimientos operativos y sus métodos de funcionamiento y su diligencia en el desempeño de sus funciones (artículo 9).
- Asistir a las instituciones, los órganos y los organismos de la Unión, así como a los Estados miembros, en la elaboración y aplicación de políticas de la Unión relativas a la ciberseguridad, en particular las políticas sectoriales sobre ciberseguridad (artículo

© Universidad Internacional de La Rioja (UNIR)

7).

- Contribuir a incrementar las capacidades de ciberseguridad a nivel de la Unión para apoyar las acciones de los Estados miembros en la prevención y respuesta a las ciberamenazas, especialmente en caso de incidentes transfronterizos.
- Promover el uso de la certificación europea de ciberseguridad, con vistas a evitar la fragmentación del mercado interior (artículo 8).
- Promoverá un alto nivel de sensibilización sobre ciberseguridad, en particular sobre la ciberhigiene y ciberalfabetización de los ciudadanos, las organizaciones y las empresas (artículo 10).
- Contribuirá a la elaboración y ejecución de la política y del derecho de la Unión (artículo 5).

Marco europeo de certificación de la ciberseguridad

Según el Reglamento sobre la Ciberseguridad (artículo 46.2), el marco europeo de certificación de la ciberseguridad define un mecanismo para instaurar esquemas europeos de certificación de la ciberseguridad y para confirmar que los productos, servicios y procesos de TIC que hayan sido evaluados cumplen con los requisitos de seguridad especificados.

La **certificación de la ciberseguridad será voluntaria**, salvo que se disponga otra cosa en el derecho de la Unión o de los Estados miembros (artículo 56.2).

Se prevé un sitio web, mantenido por ENISA, para ofrecer información y dar publicidad sobre los esquemas europeos de certificación de la ciberseguridad, los certificados europeos de la ciberseguridad y las declaraciones UE de conformidad (artículo 50).

© Universidad Internacional de La Rioja (UNIR)

Se establecen diferentes niveles de garantía de los esquemas europeos de certificación de la ciberseguridad para los productos, servicios y procesos de TIC: básico, sustancial o elevado. Los requisitos de seguridad correspondientes a cada nivel de garantía se precisarán en el esquema europeo de certificación de la ciberseguridad pertinente.

- **Nivel básico**: los productos, servicios y procesos de TIC para los que se emite el certificado o esa declaración de la conformidad cumplen los correspondientes requisitos de seguridad, incluidas las funcionalidades de seguridad, y de que se han evaluado hasta un nivel que pretende minimizar los riesgos básicos conocidos de ciberincidentes y ciberataques (artículo 52.5)
- **Nivel sustancial**: cumplen los correspondientes requisitos de seguridad, incluidas las funcionalidades de seguridad, y de que se han evaluado hasta un nivel que pretende minimizar los riesgos relacionados con la ciberseguridad conocidos, los riesgos de incidentes y los ciberataques cometidos por agentes con capacidades y recursos limitados (artículo 52.6).
- **Nivel elevado**: cumplen los correspondientes requisitos de seguridad, incluidas las funcionalidades de seguridad, y de que se han evaluado hasta un nivel que pretende minimizar el riesgo de ciberataques sofisticados cometidos por agentes con capacidades y recursos considerables (artículo 52.7).

Se permitirá la **autoevaluación de la conformidad** bajo la responsabilidad exclusiva del fabricante o proveedor de productos, servicios o procesos de TIC, y únicamente respecto a productos, servicios y procesos de TIC que presenten un bajo riesgo correspondientes al nivel de garantía básico (artículo 53).

Cada Estado designará a una o más **autoridades nacionales de certificación** de la

© Universidad Internacional de La Rioja (UNIR)

ciberseguridad en su territorio o, de mutuo acuerdo con otro Estado miembro, designará a una o más autoridades nacionales de certificación de la ciberseguridad establecidas en ese otro Estado miembro para que se encarguen de las tareas de supervisión en el Estado miembro que efectúe la designación (artículo 58.1).

El Reglamento crea un **Grupo Europeo de Certificación de la Ciberseguridad** (GECC) formado por representantes de las autoridades nacionales de certificación de la ciberseguridad o por representantes de otras autoridades nacionales pertinentes (artículo 62).

© Universidad Internacional de La Rioja (UNIR)

3.9. Reglamento sobre Ciberseguridad de la UE (CRA)

La Propuesta de Reglamento del Parlamento Europeo y del Consejo relativo a los requisitos horizontales de ciberseguridad para los productos con elementos digitales y por el que se modifica el Reglamento (UE) 2019/1020 tiene por objeto establecer:

> «a) normas para la introducción en el mercado de productos con elementos digitales a fin de garantizar la ciberseguridad de dichos productos;
>
> b) requisitos esenciales para el diseño, el desarrollo y la fabricación de productos con elementos digitales y las obligaciones de los operadores económicos en relación con dichos productos, en lo que respecta a la ciberseguridad;
>
> c) requisitos esenciales para los procesos de gestión de la vulnerabilidad establecidos por los fabricantes para garantizar la ciberseguridad de los productos con elementos digitales a lo largo de todo el ciclo de vida, y las obligaciones de los operadores económicos en relación con dichos procesos;
>
> d) normas relativas a la vigilancia del mercado y a la aplicación de los requisitos y las normas antes mencionados».

Será aplicable a los productos con elementos digitales cuyo uso previsto o razonablemente previsible incluya una conexión de datos directa o indirecta, lógica o física, a un dispositivo o red (artículo 2).

Establece las siguientes obligaciones sobre los fabricantes:

- Llevar a cabo una evaluación de los riesgos de ciberseguridad.
- Antes de introducir en el mercado un producto con elementos digitales, los fabricantes elaborarán la documentación técnica especificada en el artículo 23.
- También aplicarán o mandarán aplicar los procedimientos de evaluación de la conformidad de su elección, a los que se hace referencia en el artículo 24.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Distingue entre los requisitos aplicables a los productos con elementos digitales (art. 5) y los productos críticos con elementos digitales (art. 6).

© Universidad Internacional de La Rioja (UNIR)

3.10. Otras normas

En el ámbito financiero se ha aprobado el Reglamento (UE) 2022/2554 del Parlamento Europeo y del Consejo de 14 de diciembre de 2022 sobre la resiliencia operativa digital del sector financiero y por el que se modifican los Reglamentos (CE) nº 1060/2009, (UE) nº 648/2012, (UE) nº 600/2014, (UE) nº 909/2014 y (UE) 2016/1011, cuyo objetivo es «lograr un elevado nivel común de resiliencia operativa digital». Establece requisitos uniformes en lo que respecta a la seguridad de las redes y los sistemas de información de dichas entidades financieras.

Hay que destacar que se establece un **sistema de notificación de incidentes homogéneo**.

© Universidad Internacional de La Rioja (UNIR)

3.11. Referencias bibliográficas

Comisión Europea. (16 de diciembre de 2020). Comunicación conjunta al Parlamento Europeo y al Consejo. La Estrategia de Ciberseguridad de la UE para la Década Digital. https://eur-lex.europa.eu/legal-content/ES/TXT/HTML/?uri=CELEX:52020JC0018&from=EN

Comisión Europea. (8 de marzo de 2021a). The EU's Cybersecurity Strategy for the Digital Decade. *European Commission website.* https://digital-strategy.ec.europa.eu/en/library/eus-cybersecurity-strategy-digital-decade-0

Comisión Europea. (11 de octubre de 2021b). Proposal for directive on measures for high common level of cybersecurity across the Union. *European Commission website.* https://digital-strategy.ec.europa.eu/en/library/proposal-directive-measures-high-common-level-cybersecurity-across-union

Directiva (UE) 2022/2555 del Parlamento Europeo y del Consejo de 14 de diciembre de 2022 relativa a las medidas destinadas a garantizar un elevado nivel común de ciberseguridad en toda la Unión, por la que se modifican el Reglamento (UE) nº 910/2014 y la Directiva (UE) 2018/1972 y por la que se deroga la Directiva (UE) 2016/1148 (Directiva SRI 2). *Diario Oficial de la Unión Europea, 333,* de 27 de diciembre de 2022, pp. 80-152.https://www.boe.es/buscar/doc.php?id=DOUE-L-2022-81963

Directiva (UE) 2022/2557 del Parlamento Europeo y del Consejo de 14 de diciembre de 2022 relativa a la resiliencia de las entidades críticas y por la que se deroga la Directiva 2008/114/CE del Consejo. *Diario Oficial de la Unión Europea, 333,* de 27 de diciembre de 2022, pp. 164-198. https://www.boe.es/buscar/doc.php?id=DOUE-L-2022-81965

Recomendación del Consejo de 8 de diciembre de 2022 sobre un enfoque

© Universidad Internacional de La Rioja (UNIR)

coordinado en toda la Unión para reforzar la resiliencia de las infraestructuras críticas. *Diario Oficial de la Unión Europea, 20,* de 20 de enero de 2023, pp. 1-11. https://data.consilium.europa.eu/doc/document/ST-15623-2022-INIT/es/pdf

Real Decreto 43/2021, de 26 de enero, por el que se desarrolla el Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información. *Boletín Oficial del Estado, 24,* de 28 de enero de 2021, pp. 8187-8214. https://www.boe.es/eli/es/rd/2021/01/26/43

Reglamento (UE) 2019/881 del Parlamento Europeo y del Consejo de 17 de abril de 2019 relativo a ENISA (Agencia de la Unión Europea para la Ciberseguridad) y a la certificación de la ciberseguridad de las tecnologías de la información y la comunicación y por el que se deroga el Reglamento (UE) nº 526/2013. *Diario Oficial de la Unión Europea, 151,* de 7 de junio de 2019, pp. 15-69. https://eur-lex.europa.eu/legal-content/ES/TXT/HTML/?uri=CELEX:32019R0881&from=es

Propuesta de REGLAMENTO DEL PARLAMENTO EUROPEO Y DEL CONSEJO relativo a los requisitos horizontales de ciberseguridad para los productos con elementos digitales y por el que se modifica el Reglamento (UE) 2019/1020. *Diario Oficial de la Unión Europea, 452,* de 29 de noviembre de 2022, pp. 23-25. https://eur-lex.europa.eu/legal-content/ES/TXT/HTML/?uri=CELEX:52022PC0454&from=EN

Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información. *Boletín Oficial del Estado, 218,* de 8 de septiembre de 2018, pp. 87675-87696. https://www.boe.es/eli/es/rdl/2018/09/07/12

Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (Reglamento general de protección de datos). *Diario Oficial de la Unión Europea L 119,* 4 de mayo de 2016, pp. 1-88. https://eur-

© Universidad Internacional de La Rioja (UNIR)

lex.europa.eu/legal-content/ES/TXT/?uri=CELEX:32016R0679

Reglamento (UE) 2022/2554 del Parlamento Europeo y del Consejo de 14 de diciembre de 2022 sobre la resiliencia operativa digital del sector financiero y por el que se modifican los Reglamentos (CE) nº 1060/2009, (UE) nº 648/2012, (UE) nº 600/2014, (UE) nº 909/2014 y (UE) 2016/1011. *Diario Oficial de la Unión Europea, 333,* 27 de diciembre de 2022, pp. 1-79. https://www.boe.es/buscar/doc.php?id=DOUE-L-2022-81962

© Universidad Internacional de La Rioja (UNIR)

Guía nacional de notificación y gestión de ciberincidentes

Incibe. (28 de abril de 2020). Guía nacional de notificación y gestión de ciberincidentes. *Incibe-cert*. https://www.incibe-cert.es/guias-y-estudios/guias/guia-nacional-notificacion-y-gestion-ciberincidentes

El objeto de este documento es generar un marco de referencia consensuado por parte de los organismos nacionales competentes en el ámbito de la notificación y gestión de incidentes de ciberseguridad, encontrándose alineada con la normativa española, transposiciones europeas, así como documentos emanados de organismos supranacionales que pretenden armonizar la capacidad de respuesta ante incidentes de ciberseguridad.

La guía se consolida como una referencia de mínimos en el que toda entidad, pública o privada, ciudadano u organismo, encuentre un esquema y la orientación precisa acerca de a quién y cómo debe reportar un incidente de ciberseguridad acaecido en el seno de su ámbito de influencia.

© Universidad Internacional de La Rioja (UNIR)

1. La Directiva NIS fue transpuesta al derecho español por:

A. Real Decreto 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información.

B. Real Decreto 43/2021, de 26 de enero.

C. Ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información.

D. Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información.

2. La Directiva NIS 2 se propone en:

A. El marco de la nueva Estrategia de Ciberseguridad de la UE para la Década Digital.

B. La propia Directiva NIS, que prevé la existencia de la Directiva NIS 2.

C. Una iniciativa de ENISA.

D. No existe una Directiva NIS 2.

3. De acuerdo con la Directiva NIS 2, los órganos de dirección de las entidades esenciales e importantes:

A. Deberán asistir a formaciones en materia de gestión de riesgos de ciberseguridad.

B. No están obligados a recibir formación, pero sí a que los empleados implicados en la seguridad la reciban.

C. Es conveniente que asistan a formaciones en dicha materia.

D. No son las personas que han de recibir formación en materia de seguridad.

© Universidad Internacional de La Rioja (UNIR)

4. Según la Directiva NIS 2, los órganos de dirección de las entidades esenciales e importantes:

A. Únicamente deberán supervisar que las medidas para la gestión de riesgos de ciberseguridad adoptadas por dichas entidades sean adecuadas.

B. No es necesario que las medidas para la gestión de riesgos de ciberseguridad adoptadas por dichas entidades sean aprobadas por los órganos de dirección.

C. Deberán aprobar las medidas para la gestión de riesgos de ciberseguridad adoptadas por dichas entidades, supervisar su puesta en práctica y responder por el incumplimiento por parte de las entidades de no adoptar dichas medidas.

D. Deberán aprobar las medidas para la gestión de riesgos de ciberseguridad adoptadas por dichas entidades y supervisar su puesta en práctica, pero no responderán por el incumplimiento por parte de las entidades de no adoptar dichas medidas.

© Universidad Internacional de La Rioja (UNIR)

5. Las entidades esenciales e importantes deberán notificar, sin demora indebida, a su CSIRT o, en su caso, a su autoridad competente:

A. Cualquier incidente que tenga un impacto considerable en la prestación de sus servicios, bien porque ha causado o puede causar graves perturbaciones operativas de los servicios o pérdidas económicas para la entidad o bien porque ha afectado o puede afectar a otras personas físicas o jurídicas, al causar perjuicios materiales o inmateriales considerables.

B. Cualquier incidente que tenga un impacto considerable en la prestación de sus servicios, bien porque ha causado o puede causar graves incomodidades operativas de los servicios o bien porque ha afectado o puede afectar a otras personas físicas.

C. Cualquier incidente que tenga un impacto significativo en la prestación de sus servicios, bien porque ha causado o puede causar graves perturbaciones operativas de los servicios o pérdidas económicas para la entidad o bien porque ha afectado o puede afectar a otras personas físicas o jurídicas, al causar perjuicios materiales o inmateriales considerables.

D. Cualquier incidente que tenga trascendencia considerable en la prestación de sus servicios, bien porque ha causado o puede causar graves incomodidades operativas de los servicios o bien porque ha afectado o puede afectar a otras personas físicas.

© Universidad Internacional de La Rioja (UNIR)

6. La Directiva NIS 2:

A. Mantiene la distinción entre operadores de servicios esenciales y proveedores de servicios digitales.

B. Mantiene la distinción entre operadores de servicios esenciales y proveedores de servicios digitales e introduce que la clasificación se haga en función de su importancia.

C. Elimina la distinción entre operadores de servicios esenciales y proveedores de servicios digitales y se aplica a las entidades públicas y privadas cuyo tipo se enmarque en el de las entidades esenciales del anexo I y en el de las entidades importantes del anexo II.

D. Propone que la clasificación se haga en función del sector al que pertenezcan.

7. Respecto a los equipos de respuesta a incidentes de seguridad informática (CSIRT), de acuerdo con la Directiva NIS:

A. Cada Estado miembro designará uno o varios CSIRT.

B. Cada Estado miembro designará un CSIRT.

C. Cada Estado miembro designará un CSIRT salvo que justifique que no es necesario.

D. Cada Estado miembro designará un CSIRT salvo que llegue a un acuerdo con la Comisión Europea y justifique debidamente su decisión.

© Universidad Internacional de La Rioja (UNIR)

8. La Directiva NIS 2:

A. Restringe el ámbito de aplicación de la Directiva NIS.

B. Elimina la distinción entre operadores de servicios esenciales y proveedores de servicios digitales.

C. Indica que debe notificarse cualquier incidente que tenga un impacto en la prestación de sus servicios.

D. No existe una Directiva NIS 2, sino un Reglamento europeo en materia de ciberseguridad.

9. La Directiva NIS creó un grupo de cooperación que se mantiene en la Directiva NIS 2:

A. Formado por representantes de los Estados miembros, la Comisión y la ENISA.

B. Formado por representantes de los Estados miembros.

C. Formado por representantes de los Estados miembros y la ENISA.

D. Formado por representantes de los Estados miembros y sus CSIRT.

© Universidad Internacional de La Rioja (UNIR)

10. Las entidades afectadas deberán presentar al CSIRT o, en su caso, a la autoridad competente:

A. Una alerta temprana, sin demora indebida y, en cualquier caso, en el plazo de veinticuatro horas desde que se haya tenido constancia del incidente significativo y una notificación del incidente sin demora indebida y, en cualquier caso, en el plazo de setenta y dos horas desde que se haya tenido constancia del incidente significativo.

B. Una alerta temprana, sin demora indebida y, en cualquier caso, en el plazo de setenta y dos horas desde que se haya tenido constancia del incidente significativo y una notificación del incidente sin demora indebida y, en cualquier caso, en el plazo de veinticuatro horas desde que se haya tenido constancia del incidente significativo.

C. Una alerta temprana, sin demora indebida y, en cualquier caso, en el plazo de setenta y dos horas desde que se haya tenido constancia del incidente significativo y una notificación del incidente sin demora indebida y, en cualquier caso, en el plazo de noventa y seis horas desde que se haya tenido constancia del incidente significativo.

D. Una alerta temprana, sin demora indebida y, en cualquier caso, en el plazo de treinta y seis horas desde que se haya tenido constancia del incidente significativo y una notificación del incidente sin demora indebida y, en cualquier caso, en el plazo de setenta y dos horas desde que se haya tenido constancia del incidente significativo.

© Universidad Internacional de La Rioja (UNIR)